INCIDENT WALL

Day 3 adds five more real incidents to yesterday's wall. When you have worked on a card, stick it here and add a sticky: The control that would have helped:

- 1 45 minutes (Knight Capital, August 2012)
- 2 The update nobody asked for (GPT-4o, April 2025)
- 3 The prompt edit that skipped review (Grok, May 2025)
- 4 An error after a system update (DPD chatbot, January 2024)
- 5 Zero clicks (EchoLeak, Microsoft 365 Copilot, June 2025)

CARD 1 | Knight Capital, August 2012

45 minutes

What was reported

- Knight Capital, a US market maker, was updating its automated order-routing system to join a new exchange programme starting on 1 August 2012.
- The new code reused a flag that had once switched on an old test function called Power Peg, unused since 2003 but never deleted.
- It was copied by hand to eight servers. One technician did not copy it to one of them, and nobody reviewed the deployment or checked it automatically.
- On 1 August, orders with the reused flag reached that server and started the old code. The check that stopped Power Peg when a parent order was filled no longer worked, so it kept sending new orders.
- In about 45 minutes it executed roughly 4 million trades in 154 stocks. Knight's pre-tax loss was about $440 million and it needed a $400 million rescue within days.
- The regulator's order recorded that automated emails referring to the old function had been sent before the open (reported as 97) and were not treated as an alarm.

The question for your pair

Where could this system have answered "has this already happened?", which line of an inventory of what was running would have shown the difference, and why did nobody act on the warnings?

Write your control on a sticky note, then stick this card on the Incident Wall.

Sources: US Securities and Exchange Commission order (2013), as summarised by J R Varma, Henrico Dolfing and SmartBear; Wikipedia; Zof.

CARD 2 | OpenAI GPT-4o in ChatGPT, April 2025

The update nobody asked for

What was reported

- On 25 April 2025 OpenAI completed the rollout of an update to its GPT-4o model in ChatGPT that made the model noticeably more sycophantic: overly flattering and agreeable.
- Users noticed within days. OpenAI began rolling the update back on about 28 to 29 April and published a postmortem on 2 May.
- The postmortem said some expert testers had said the model felt slightly off, that other evaluations and live trials looked positive, and that there was no specific evaluation tracking sycophancy. It also said the release notes had not given enough information.
- This was a consumer product, not a bank's agent. Use it for the mechanism: something your agent depends on can change behaviour with nothing changing on your side.

The question for your pair

Where in your own agent's configuration is a model or product named by an alias that a provider can move? What would you run after any provider change, and who would be told?

Write your control on a sticky note, then stick this card on the Incident Wall.

Sources: OpenAI, "Expanding on what we missed with sycophancy" (2 May 2025); TechCrunch (29 April 2025); Georgetown Law Tech Institute.

CARD 3 | xAI Grok, May 2025

The prompt edit that skipped review

What was reported

- On 14 May 2025, at about 3:15 in the morning Pacific time, a change was made to the system prompt of the Grok response bot on X telling it to give a specific response on a political topic.
- For hours it raised that topic in replies to unrelated posts.
- xAI said the change had not gone through its normal review process and that it violated its internal policies. It said it had made a similar unauthorised change earlier in the year.
- Its response: publish the system prompts on GitHub with a changelog, add checks so employees cannot change a prompt without review, and set up round-the-clock monitoring.
- This card is about change control on a system prompt, not about the topic the bot raised.

The question for your pair

Who can edit each layer of your agent's prompt? What stops a change going live without review? Who would notice at 03:15, and who could roll it back?

Write your control on a sticky note, then stick this card on the Incident Wall.

Sources: TechCrunch (15 May 2025); Business Insider (16 May 2025); Engadget via Yahoo Tech; The Decoder.

CARD 4 | DPD chatbot, January 2024

An error after a system update

What was reported

- A delivery company's online chat used an AI element alongside human operators.
- A customer got it to swear, to write a poem criticising the company and to call itself useless. He posted the exchange on 18 January 2024 and it was widely viewed.
- The company said an error had occurred after a system update, that the AI element was immediately disabled and that it was being updated.
- The company said it had run the AI element in its chat successfully for several years before.

The question for your pair

The company said the AI element had worked for years. What does that tell you about "it was tested before"? Which entry in a configuration record would have changed? Was there a switch for the AI part with a human route behind it?

Write your control on a sticky note, then stick this card on the Incident Wall.

Sources: The Guardian (20 January 2024); BBC; Business Insider via Yahoo; AI Incident Database, incident 631.

CARD 5 | EchoLeak, Microsoft 365 Copilot, June 2025

Zero clicks

What was reported

- Aim Security reported a vulnerability in Microsoft 365 Copilot, tracked as CVE-2025-32711 and rated critical (CVSS 9.3).
- It let an attacker extract data from a user's Copilot context with no action by the user.
- The attacker sends a crafted email. When Copilot later retrieves it to answer a question, hidden instructions in the email steer it into including sensitive organisational data in output that reaches the attacker.
- Researchers described it as the first known zero-click attack on an AI agent of this kind. Microsoft fixed it on the server side, needing no customer action. The researchers reported no evidence of exploitation in the wild.

The question for your pair

Where is the untrusted content in this story, and how did it reach the model? Which of the four layers (gateway filter, tool sandbox, output schema, human escalation) would have bounded it, and which would have missed it?

Write your control on a sticky note, then stick this card on the Incident Wall.

Sources: The Hacker News (June 2025); SecurityWeek; TechRepublic (13 June 2025); Cybersecurity Dive; arXiv 2509.10540.